

Banner Grabbing: Descubriendo información sobre los servicios

En esta clase vamos a ver con qué entorno al laboratorio vamos a estar trabajando y vamos a aprender qué es la técnica de Banner Grabbing, ambas técnicas, tanto la pasiva como la activa. Además también veremos algunas herramientas como Netcat (nc), Telnet, cURL o Wget.

Lab environment

El entorno de laboratorio que tenemos para esta sesión es el siguiente:

Por un lado tenemos la mítica Kali Linux, cuya interfaz de red es la 10.0.1.0/24, en concreto la IP 10.0.1.5 como decostumbre.

Por otro lado tenemos una máquina con metasploitable, que he cogido esta máquina en concreto porque era muy útil por la cantidad de servicio que expone al exterior y que nos va a permitir identificar todos ellos de manera fácil y rápida.

```
vagrant@ubuntu:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 08:00:27:42:51:79 brd ff:ff:ff:ff:ff:ff
    inet 10.0.1.9/24 brd 10.0.1.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe42:5179/64 scope link
        valid_lft forever preferred_lft forever
3: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP group default
    link/ether 02:42:05:15:ec:2e brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:5ff:fe15:ec2e/64 scope link
        valid_lft forever preferred_lft forever
5: veth8083dfe: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master docker0 state UP group default
    link/ether 0e:51:08:81:50:e8 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::c51:8ff:fe81:50e8/64 scope link
        valid_lft forever preferred_lft forever
vagrant@ubuntu:~$ _
```

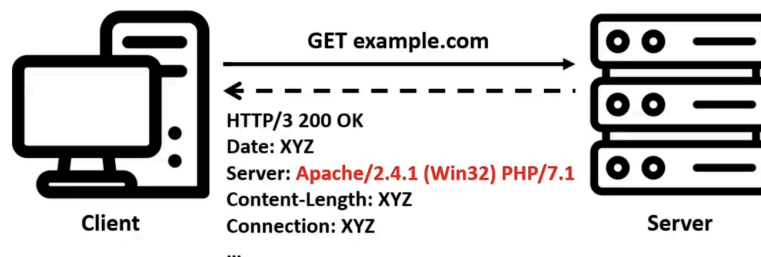
Si ejecutamos el comando `ip a` podemos ver que aparte de todas las interfaces de red que contiene, tiene una que es la eth cuya IP es la 10.0.1.9. Es decir, tanto la máquina Kali como la metasploitable están en la misma red.

Pues vamos a comenzar ahora sí con la teoría.

Banner Grabbing

Banner Grabbing

- Banner Grabbing is the term used to refer to the technique of grabbing information of a system available on a certain network and all the services running on its open ports.



El Banner Grabbing es una técnica que consiste en obtener toda la información sobre un servicio o sistema remoto al interceptar y analizar los banners o encabezados que este devuelve al realizarse una conexión.

Estos banners suelen contener datos valiosos como la versión del software, sistema operativo y otros detalles que pueden ser utilizados para evaluar la seguridad del sistema.

En el ejemplo de arriba vemos cómo se realiza una conexión al servidor remoto y aprovechando que éste no responde, interceptamos y analizamos dicha respuesta. Esta respuesta incluye un banner.

Algunas veces, en el caso de aplicaciones HTTP, el banner viene incluido en una cabecera de respuesta denominada Server.

En este caso vemos que la cabecera Server nos dice que la versión del servidor web es la Apache 2.4.1, la etiqueta Win32 nos está indicando que este servidor Apache está ejecutándose sobre un entorno Windows y la versión de PHP nos dice que se está utilizando la versión 7.1.

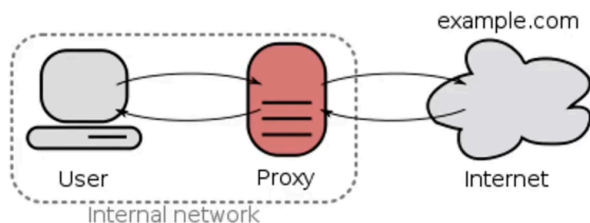
Al final el objetivo de esta técnica es ser capaces de identificar las versiones de los servicios para encontrar en una fase posterior posibles vulnerabilidades en el caso de que éstos estén desactualizados.

Además, esta técnica también nos permite perfilar la superficie de ataque y analizar posibles puntos de entradas para realizar posteriormente pruebas de pentesting.

Passive Banner Grabbing

Techniques: Passive Banner Grabbing

- This technique allows you to collect information discreetly by using intermediary software or platforms as a gateway.



Vamos a comenzar viendo la técnica de Passive Banner Grabbing o Banner Grabbing pasivo.

Este es un enfoque discreto para obtener información sobre servicios o sistemas remotos sin necesidad de interactuar directamente con ellos.

Es decir que a diferencia del Banner grabbing tradicional o el Banner grabbing activo, no vamos a realizar ninguna solicitud de forma activa y directa.

En su lugar recopilaremos los datos de manera pasiva, cómo por ejemplo observando el tráfico de red, capturaremos el tráfico y posteriormente analizaremos la captura de ese tráfico, donde entrarán en juego herramientas como p0f, que la mencionamos en la última clase para identificar los sistemas operativos subyacentes de los juegos activos de nuestra red.

Otra forma de realizar un Banner grabbing pasivo es utilizar un servidor proxy anónimo o una VPN.

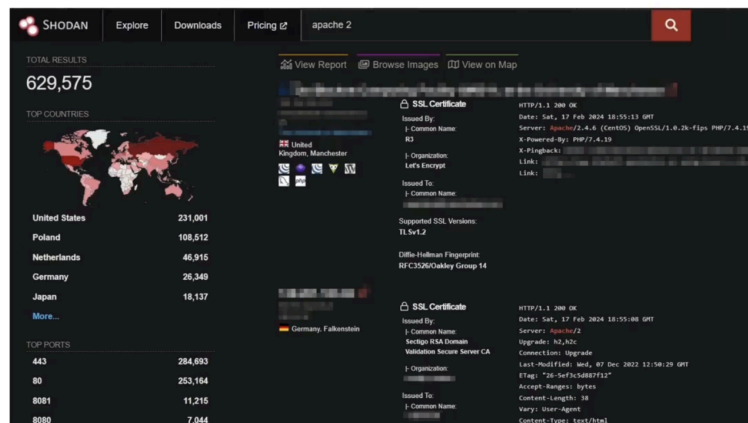
También existen otras herramientas como SHODAN, es la herramienta perfecta para obtener información valiosa de manera pasiva. Se trata de un motor de búsqueda especializado en dispositivos conectados a Internet.

A diferencia de los motores de búsqueda tradicionales, SHODAN se centra en buscar dispositivos específicos como servidores, routers, cámaras web y mucho más.

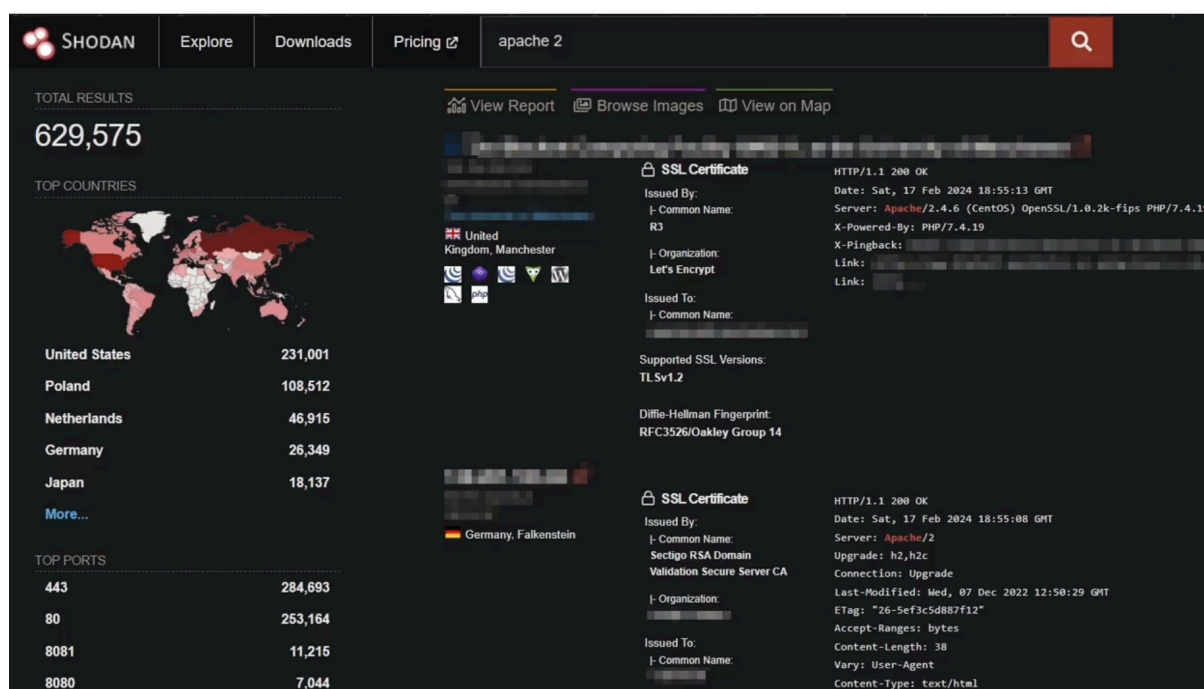
Su capacidad para indexar detalles técnicos y banners nos brinda detalles precisos de forma pasiva.

Passive Banner Grabbing: Shodan

- Shodan is the world's first search engine for devices connected to Internet.



Ejemplo de resultados obtenidos con Shodan:



En la imagen de arriba podemos ver que mediante una simple búsqueda donde indico Apache2, nos aparecen más de 600.000 resultados alrededor de todo el mundo. El primero por ejemplo es de Reino Unido y el segundo está en Alemania.

Estos resultados no solo nos ofrecen datos del servidor en cuestión, sino que también nos dice datos de cuando fueron registrados, datos de ubicación, certificado SSL, entre otros muchos más.

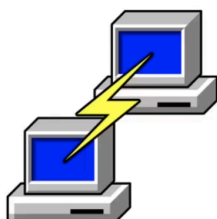
Active Panel Grabbing

Techniques: Active Banner Grabbing

- Most popular technique where packets are sent to a remote host, and the responses are analyzed to gather information



NetCat



Telnet



cURL



GNU Wget

Ahora vamos a ver la técnica de Active Panel Grabbing o Banner Grabbing Activo. Esta técnica, a diferencia del panel Driving pasivo, sí que implica la interacción directa con el servicio o el servidor objetivo para obtener detalles sobre la versión y otros atributos del sistema.

Por tanto, a diferencia del enfoque pasivo, en esta técnica sí que generamos algún tipo de ruido, aunque mucho menos por supuesto que en un ataque por ejemplo de fuerza bruta o de búsqueda de directorios.

En esta sección nos centraremos en varias herramientas esenciales para realizar este Active Banner Grabbing.

Una de ellas es NetCat y es utilizada para establecer conexiones TCP-IP y enviar solicitudes personalizadas a servicios específicos.

La siguiente herramienta es Telnet, una herramienta muy versátil que permite la comunicación con servicios remotos a través del protocolo Telnet y que es ideal para banner grabbing interactivo.

Por otro lado tenemos la herramienta cURL y Wget. Ambas herramientas son de línea de comandos y facilitan la transferencia de datos desde o hacia servidores permitiendo extraer banners de una forma eficiente y rápida.

Vamos a ver ahora desde un punto de vista mucho más práctico y a conocer en detalle cada una de estas herramientas.

Práctica de Active Banner Grabbing

Para comenzar con esta parte práctica vamos a hacer rápidamente un escaneo de puertos a la máquina metasploitable para ver qué puertos tiene abierto y comenzar a investigar qué servicios y qué versiones corre cada uno de ellos.

`nmap 10.0.1.9`

```
(kali㉿kali)-[~]  
$ nmap 10.0.1.9  
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-17 17:35 EST  
Nmap scan report for 10.0.1.9  
Host is up (0.0013s latency).  
Not shown: 991 filtered tcp ports (no-response)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
22/tcp    open  ssh  
80/tcp    open  http  
445/tcp   open  microsoft-ds  
631/tcp   open  ipp  
3000/tcp  closed ppp  
3306/tcp  open  mysql  
8080/tcp  open  http-proxy  
8181/tcp  closed intermapper  
  
Nmap done: 1 IP address (1 host up) scanned in 4.67 seconds
```

El análisis de Nmap nos dice que el puerto 21, el 22, el 80 son puertos que están abiertos. También tenemos otros puertos como el 3306 que se encuentra abierto y donde está un MySQL o un HTTP proxy (el puerto 8080) y otros cerrados como el 3000 y el 8181.

Una vez analizados los puertos vamos a investigar un poco más en detalle qué tiene cada uno de ellos.

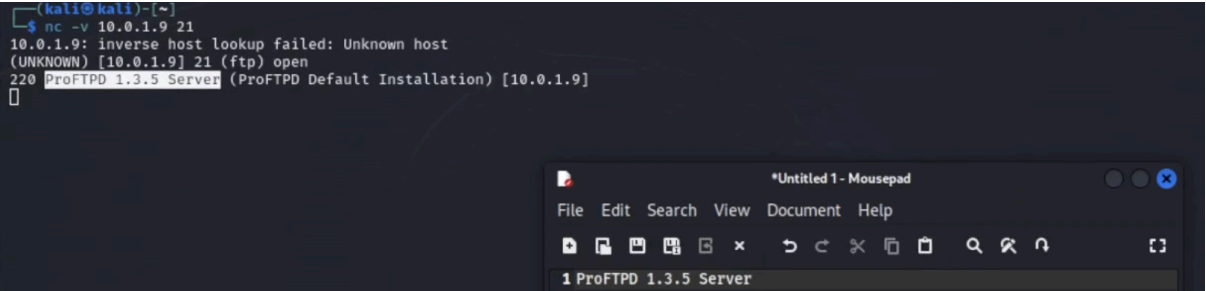
Netcat

Vamos a comenzar por analizar que hay en el puerto 21 para ello vamos a utilizar netcat.

Ejecutando el comando `nc -v` que es la IP de la máquina objetivo e indicando el puerto, que en este caso es el 21, podremos conocer más detalles de lo que hay detrás de este servicio.

```
nc -v 10.0.1.9 21
```

Por convención el puerto 21 se suele usar para un servidor de ficheros y en este caso es lo que proFTPD 1.3.5 este es el servidor de ficheros que tiene la máquina metasploitable 3. Vamos a copiar esta versión y nos vamos a apuntar el número de versión en un bloc de notas para luego, una vez finalizado todo el análisis, recopilar qué versiones y qué servicios tenemos.



```
(kali@kali)~$ nc -v 10.0.1.9 21
10.0.1.9: inverse host lookup failed: Unknown host
(UNKNOWN) [10.0.1.9] 21 (ftp) open
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation) [10.0.1.9]
^
```

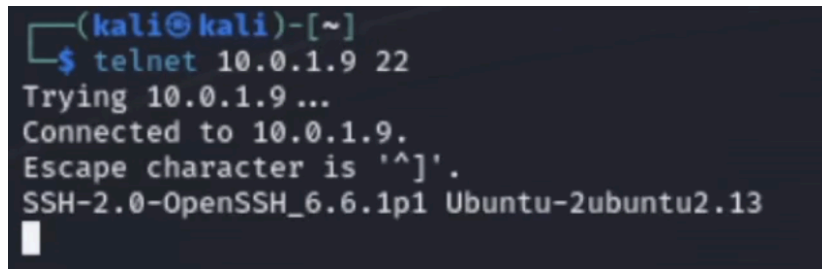
The screenshot shows a terminal window with the netcat command being executed. The output indicates a successful connection to port 21 on 10.0.1.9, identifying it as a ProFTPD 1.3.5 Server. In the foreground, there is a window titled '*Untitled 1 - Mousepad' with a menu bar (File, Edit, Search, View, Document, Help) and a toolbar. The text '1 ProFTPD 1.3.5 Server' is visible in the mousepad window.

Telnet

Continuamos con nuestro análisis y ahora vamos a ver Telnet.

Vamos a escribir telnet, la IP de la máquina objetivo 10.0.1.9 y el puerto que vamos a investigar, en este caso es el puerto ssh, el puerto 22.

```
telnet 10.0.1.9 22
```



```
(kali@kali)-[~]  
$ telnet 10.0.1.9 22  
Trying 10.0.1.9 ...  
Connected to 10.0.1.9.  
Escape character is '^]'.  
SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13  
█
```

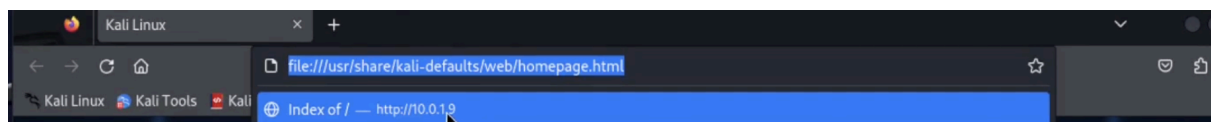
Ejecutamos y vemos que nos dice que en este caso tenemos SSH-2.0 cuyo servidor es el OPENSSH_6.6.1p1. También nos dice alguna información sobre la máquina, se trata de una máquina Ubuntu cuya versión es 2.13.

Vamos a guardarlo como el anterior en nuestro blog de notas y seguimos investigando.

Wget

A continuación vamos a investigar sobre el puerto 80. Vamos a ver en el navegador qué es lo que contiene este puerto. Para ello escribimos aquí la dirección IP de la máquina metasploitable, la tengo por aquí.

```
http://10.0.1.9
```



Vemos que encontramos un sitio donde indexa diferentes directorios de la máquina.

Index of /			
Name	Last modified	Size	Description
 chat/	2020-10-29 19:37	-	
 drupal/	2011-07-27 20:17	-	
 payroll_app.php	2020-10-29 19:37	1.7K	
 phpmyadmin/	2013-04-08 12:06	-	
Apache/2.4.7 (Ubuntu) Server at 10.0.1.9 Port 80			

Si entramos en el directorio de chat vemos que nos lleva a <http://10.0.1.9/chat/>, una página de chat donde podemos interactuar.

También tenemos la página de drupal en <http://10.0.1.9/drupal/>, tenemos la página de payroll en <http://10.0.1.9/payroll/app.php> y la página de phpmyadmin en <http://10.0.1.9/myadmin/>.

Lo que iremos haciendo ahora es con wget investigar cada uno de estos subdirectorios para ver qué información en conjunto nos puede proveer.

Comenzaremos viendo por ejemplo el phpmyadmin.

Para ello escribimos wget, la ip de la máquina objetivo, en este caso vamos a poner como un URL y escribiremos el parámetro -q y -S.

```
wget http://10.0.1.9/phpmyadmin/ -q -S
```

Con el parámetro -q le estamos indicando que vamos a entrar en el modo quiet, es decir, el modo silencioso.

No nos imprimirá información sobre la petición que realice a esta página, pero con el modo -S le indicamos que habilite la impresión de esos parámetros de las peticiones HTTP.

Pulsamos enter y vemos que nos imprime las cabeceras.

```
$ wget http://10.0.1.9/phpmyadmin/ -q -S
HTTP/1.1 200 OK
Date: Sat, 17 Feb 2024 22:43:03 GMT
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.4.5
Set-Cookie: phpMyAdmin=5a2b35c292725ee1c3e0ac6f84da5f4c6feb64a8; path=/phpmyadmin/; HttpOnly
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: private, max-age=10800, pre-check=10800
Last-Modified: Mon, 08 Apr 2013 12:06:50 GMT
Set-Cookie: pma_lang=en; expires=Mon, 18-Mar-2024 22:43:03 GMT; path=/phpmyadmin/; httponly
Set-Cookie: pma_collation_connection=utf8_general_ci; expires=Mon, 18-Mar-2024 22:43:03 GMT; path=/phpmyadmin/; httponly
Set-Cookie: pma_mcrypt_iv=q93LW0njrUUX3D; expires=Mon, 18-Mar-2024 22:43:03 GMT; path=/phpmyadmin/; httponly
Set-Cookie: phpMyAdmin=aa5b24081b9e105f607739e211b338cc64594be9; path=/phpmyadmin/; HttpOnly
Vary: Accept-Encoding
Content-Length: 7128
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=utf-8
```

En cuanto a la información, por un lado tenemos el servidor, que se trata de un Apache 2.4.7. También nos da algunos datos de la versión de php que se está utilizando, es la versión PHP/5.4.5.

Vamos a copiar estos datos y a guardarlo en nuestro bloc de notas con el resto de la información.

Vamos a repetir este proceso con el resto de páginas: /payroll_app.php, /drupal y /chat.

Borramos la consola y escribimos aquí en siguiente comando de wget:

```
wget http://10.0.1.9/payroll_app.php/ -q -S
```

```
$ wget http://10.0.1.9/payroll_app.php/ -q -S
HTTP/1.1 200 OK
Date: Sat, 17 Feb 2024 22:43:51 GMT
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.4.5
Vary: Accept-Encoding
Content-Length: 433
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html
```

Vemos que la salida en este caso es más escueta, pero que igualmente nos está devolviendo que el servidor es un Apache 2.4.7 y que la versión de PHP es la 5.4.5.

Seguimos con el siguiente servicio web, En este caso le otorga el turno a /drupal.

```
wget http://10.0.1.9/drupal/ -q -S
```



```
$ wget http://10.0.1.9/drupal/ -q -S
HTTP/1.1 200 OK
Date: Sat, 17 Feb 2024 22:44:14 GMT
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.4.5
Expires: Sun, 19 Nov 1978 05:00:00 GMT
Last-Modified: Sat, 17 Feb 2024 22:44:14 +0000
Cache-Control: no-cache, must-revalidate, post-check=0, pre-check=0
ETag: "1708209854"
X-Generator: Drupal 7 (http://drupal.org)
Vary: Accept-Encoding
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Transfer-Encoding: chunked
Content-Type: text/html; charset=utf-8
```

Vemos que igualmente el servidor es un Apache 2.4.7, la versión de PHP es la 5.4.5 y además nos dice por aquí que se trata de un Drupal 7. Nos podemos guardar este dato por si nos sirve más adelante.

Por último, vamos a ver el /chat a ver si encontramos algo de información.

```
wget http://10.0.1.9/chat/ -q -S
```

```
$ wget http://10.0.1.9/chat/ -q -S
HTTP/1.1 200 OK
Date: Sat, 17 Feb 2024 22:44:45 GMT
Server: Apache/2.4.7 (Ubuntu)
X-Powered-By: PHP/5.4.5
Access-Control-Allow-Origin: *
Access-Control-Allow-Credentials: true
Set-Cookie: PHPSESSID=3e8090800bd6db1eeaf126b7890a8782; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 771
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html
```

Vemos que igualmente el servidor es un apache 2.4.7, la versión de apache es la 5.4.5 y no vemos nada más de información relevante entre los datos de las cabeceras recibidas.

Síntesis de la información recolectada con nuestras herramientas de banner grabbing activo:

```
1 ProFTPD 1.3.5 Server
2 SSH-2.0-OpenSSH_6.6.1p1 Ubuntu-2ubuntu2.13
3 Server: Apache/2.4.7 (Ubuntu)
4 X-Powered-By: PHP/5.4.5Drupal 7
```


Nos quedamos con que estos servicios web que investigamos contienen un servidor FTPD, un servidor SSH cuya versión es la 6.6.1, un servidor Apache 2.4.7, una versión de PHP 5.4.5 y también corre un Drupal 7 por ahí.

Al final, conocer las versiones de estos servicios y qué servicios están corriendo en una máquina nos permitirá en posteriores etapas de una auditoría y de unas pruebas de pentesting, conocer y ver qué puntos de entrada tenemos para seguir investigando y conseguir posteriormente entrar en el sistema.

Banner Grabbing: Detectando servicios y versiones con Nmap

Ahora vamos a estar hablando sobre la detección de servicios y de versiones, pero esta vez usando Nmap. Voy a presentar qué entorno de laboratorio vamos a estar usando y también os presentaré un comando para detectar los servicios y las versiones con Nmap.

Por último veremos un comando que le he llamado un todo en uno (all-in-one) ya que nos permite realizar un escaneo para detectar el sistema operativo, servicio, versiones, etc.

Lab environnement

Por un lado tenemos nuestra máquina Kali Linux que cuenta con la dirección IP 10.0.1.5. Por otro lado tenemos la máquina metasploitable 3, cuya dirección IP es la 10.0.1.9.

Esta máquina cuenta con todos los servicios que veíamos en la anterior sesión y que vamos a estar esta vez detectando y obteniendo la versión de cada uno de ellos utilizando Nmap.

Service and Version Detection with nmap -sV

Service and Version Detection with Nmap

```
nmap -sV <target>
```



Enable version detection

OPTIONAL:

--allports

--version-intensity <0-9>

--version-trace

A continuación vamos a ver cómo detectar servicios y versiones con Nmap.

Primero vamos a verlo desde un punto de vista teórico, es decir, sobre el papel, y después lo veremos desde un punto de vista práctico.

En la máquina Kali y usando la máquina metasploitable 3, Nmap nos ofrece potentes opciones para detectar versiones y servicios con gran precisión.

Por un lado tenemos el comando `nmap -sV`, que habilita la detección de las versiones. Junto a este parámetro podemos agregar otros opcionales.

Por ejemplo, el parámetro `--allports` escanea todos los puertos en lugar de los mil puertos comunes que por defecto escanea Nmap.

También podemos controlar el nivel de intensidad del escaneo de versiones, es decir, podemos introducir un comando que es `--version-intensity 0-9` y un número entre 0 al 9. Valores más altos, como por ejemplo el 9, aumentan la probabilidad de detectar las versiones de los servicios, pero sin embargo tienen otras desventajas como por ejemplo que son más intrusivos y generan mucho más ruido.

Por último, otro comando opcional es `--version-trace`.

Este comando proporciona un rastreo detallado de la información de versión durante el escaneo.

El resultado es un subconjunto de datos de lo que obtendremos con el parámetro `--packet-trace`.

Vamos a ver ahora de forma práctica el comando `nmap -sV`.

```
(kali@kali)-[~]
$ nmap -sV 10.0.1.9
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-18 04:16 EST
Nmap scan report for 10.0.1.9
Host is up (0.00070s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            ProFTPD 1.3.5
22/tcp    open  ssh            OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http           Apache httpd 2.4.7
445/tcp    open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp            CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql          MySQL (unauthorized)
8080/tcp   open  http           Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
Service Info: Hosts: 127.0.1.1, UBUNTU; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.07 seconds
```

Para ello vamos a una terminal de Kali y escribimos `nmap -sV` y el target, que en este caso es la máquina 10.0.1.9. Ejecutamos y vemos qué información nos trae.

Vemos que nos da algunos números de versión que ha encontrado, en otros no ha podido encontrar nada.

Vamos ahora a ver si con el parámetro `--allports` sacamos más información aún. Ejecutamos y vemos que aparece.

```
└─$ nmap -sV --allports 10.0.1.9
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-18 04:17 EST
Nmap scan report for 10.0.1.9
Host is up (0.00081s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.7
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp      CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql    MySQL (unauthorized)
8080/tcp   open  http     Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
Service Info: Hosts: 127.0.1.1, UBUNTU; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.98 seconds
```

Podemos ver que no ha encontrado nada extra dentro de esos mil puertos típicos que son los que detecta Nmap. Por lo menos no se le dice que busque entre los 65.536 puertos existentes.

Por tanto vamos a continuar nuestra búsqueda y vamos a ir modificando algunos parámetros para ver si podemos extraer más información de las versiones que no ha conseguido detectar por completo.

Vamos ahora a añadir el parámetro indicado para qué que en lugar de utilizar la versión intensity que utiliza por defecto, utilice la más alta posible, esto es para obtener toda la información posible, aunque sí que genera más ruido y genera un extra de peticiones y actividad contra la máquina metasploitable 3, pero como estamos en un entorno local y de laboratorio esto no nos preocupa.

Escribimos entonces `--version-intensity 9` con el número más alto que es el 9. Damos a enter y vemos que resultados aparece.

```

$ nmap -sV --version-intensity 9 10.0.1.9
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-18 04:19 EST
Nmap scan report for 10.0.1.9
Host is up (0.0029s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          ProFTPD 1.3.5
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
445/tcp    open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
631/tcp    open  ipp          CUPS 1.7
3000/tcp   closed ppp
3306/tcp   open  mysql        MySQL (unauthorized)
8080/tcp   open  http         Jetty 8.1.7.v20120910
8181/tcp   closed intermapper
Service Info: Host: UBUNTU; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.61 seconds

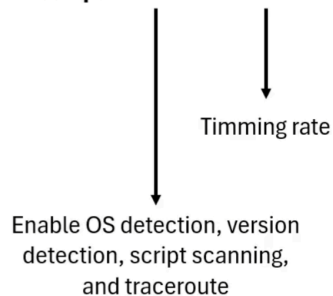
```

Tenemos un Jetty 8.1.7, es decir, un servidor HTTP basado en Java. También tenemos CUPS 1.7, Samba 3.x, Apache httpd 2.4.7, la versión de OpenSSH es la 661 y un servidor FTPD 1.3.5.

All-in-one Nmap scan with nmap -A

All-in-one Nmap scan

`nmap -A -T<0-5> <target>`



Otra alternativa al parámetro `-sV` que veíamos antes en nmap es el parámetro `-A`, que al igual que `-sV` habilita la detección de las versiones entre otras cosas, como por ejemplo detecta el sistema operativo, escanea usando script NSE y también utiliza traceroute.

Además podemos ajustar la velocidad de detección gracias al parámetro `-T` y un número que indicamos entre 0 y 5, donde 0 forzará a nmap a lanzar los diferentes paquetes de una forma más pausada y lenta y 5 de una forma mucho más rápida.

Vamos a ver al igual que antes este tipo de comandos como funciona en la práctica.

Vamos ahora a ver el comando nmap -A, para ello volvemos a nuestra terminal Kali y escribimos nmap el parámetro -A y vamos a escribirle un timing rate, en este caso creo que con un -T4 vamos a ir bastante bien. Escribimos ahora la dirección IP de nuestro target, que es la 10.0.1.9 y damos a ejecutar.

```
nmap -A -T4 10.0.1.9
```

```
└─$ nmap -A -T4 10.0.1.9
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-02-18 04:23 EST
Nmap scan report for 10.0.1.9
Host is up (0.0016s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      ProFTPD 1.3.5
22/tcp    open  ssh      OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 2b:2e:1f:a4:54:26:87:76:12:26:59:58:0d:da:3b:04 (DSA)
|   2048 c9:ac:70:ef:f8:de:8b:a3:a3:44:ab:3d:32:0a:5c:6a (RSA)
|   256  c0:49:cc:18:7b:27:a4:07:0d:2a:0d:bb:42:4c:36:17 (ECDSA)
|_  256  a0:76:f3:76:f8:f0:70:4d:09:ca:e1:10:fd:a9:cc:0a (ED25519)
80/tcp    open  http     Apache httpd 2.4.7 ((Ubuntu))
|_ http-ls: Volume /
|_  SIZE  TIME      FILENAME
|_  -    2020-10-29 19:37  chat/
|_  -    2011-07-27 20:17  drupal/
```

```
| 1.7K 2020-10-29 19:37 payroll_app.php
| -    2013-04-08 12:06 phpmyadmin/
|_
|_ http-title: Index of /
|_ http-server-header: Apache/2.4.7 (Ubuntu)
445/tcp   open  netbios-ssn Samba smbd 4.3.11-Ubuntu (workgroup: WORKGROUP)
631/tcp   open  ipp        CUPS 1.7
|_ http-robots.txt: 1 disallowed entry
|_ /
|_ http-server-header: CUPS/1.7 IPP/2.1
|_ http-methods:
|_   Potentially risky methods: PUT
|_ http-title: Home - CUPS 1.7.2
3000/tcp  closed ppp
3306/tcp  open  mysql      MySQL (unauthorized)
8080/tcp  open  http       Jetty 8.1.7.v20120910
|_ http-title: Error 404 - Not Found
|_ http-server-header: Jetty(8.1.7.v20120910)
8181/tcp  closed intermapper
Service Info: Host: UBUNTU; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Host script results:
| smb2-security-mode:
|   3:1:1:
|_   Message signing enabled but not required
|_ smb-os-discovery:
|_   OS: Windows 6.1 (Samba 4.3.11-Ubuntu)
|_   Computer name: ubuntu
|_   NetBIOS computer name: UBUNTU\x00
|_   Domain name: \x00
|_   FQDN: ubuntu
|_   System time: 2024-02-18T09:24:05+00:00
|_ clock-skew: mean: 5s, deviation: 3s, median: 3s
|_ smb-security-mode:
|_   account_used: guest
|_   authentication_level: user
|_   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_ smb2-time:
|_   date: 2024-02-18T09:24:02
|_   start_date: N/A
```

```
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 52.01 seconds
```

Vale, pues tras un ratito, unos 50 segundos, hemos visto que nos ha sacado un montón de información. Recordar que este comando va a tardar más y es normal ya que saca versiones del sistema operativo, versiones de los servicios, ejecuta algunos scripts de NSE por detrás y en general obtiene mucha más información de lo normal.

Vamos a analizar un poco todo lo que ha sacado.

Viendo desde el principio por aquí tenemos el puerto 21 que está corriendo el servicio FTP con la versión ProFTPD 1.3.5.

Por otro lado tenemos la versión de SSH que es la 6.6.1 en el puerto 22, también nos da aquí algunos fingerprint de este host SSH.

En el puerto 80, aparte de decirnos que está corriendo un servidor apache 2.4.7, nos dice que este cuando accede encuentra diferentes URL chat, drupal, payroll_app y phpmyadmin que son las que veíamos en la anterior clase.

Además nos dice que el título de esta pestaña http es Index of / y que los headers indican de nuevo que es un Apache 2.4.7.

En el puerto 445 tenemos un Samba cuya versión es 4.3.11 y el grupo de trabajo (workgroup) es Worldgroup.

En el puerto 631 tenemos un CUPS, la versión es 1.7.

En cuanto al puerto 3306, con MySQL, todavía no ha conseguido obtener la versión.

En cuanto al servidor HTTP Jetty nos dice lo mismo que antes, que la versión es 8.1.7, sin embargo ahora nos da una versión mucho más exacta (v20120910).

Esta versión también nos ofrece información del sistema Ubuntu basado en Unix.

Nos dice algunos resultados al ejecutar el script contra el host.

Nos dice que el nombre de la máquina es Ubuntu.

Nos dice también la fecha del sistema, que está a 18 de febrero de 2024.

Y eso es todo lo que podemos intuir por ahora de estos resultados del comando

`nmap -A`

Conclusiones

Hemos explorado las diversas técnicas de Banner Grabbing que nos permiten obtener información valiosa sobre sistemas y servicios en línea.

Hemos cubierto dos enfoques, el Banner Grabbing Pasivo, donde hemos utilizado Wireshark y haciendo uso de buscadores como Shodan para obtener información a nivel global.

También hemos hablado de técnicas de Banner Grabbing Activo mediante herramientas como Netcat, cURL, Telnet y Wget. Hemos visto y explorado cómo funcionan estas herramientas, que datos nos pueden ofrecer, algunos más específicos, otros son más generales, pero por lo general funcionan bastante bien.

Espero que ya conozcas qué comandos existen en nmap para detectar las versiones, los servicios y ese comando todo en uno que os he presentado con el parámetro que es muy útil en ciertas ocasiones donde queremos obtener toda la información de golpe para luego analizarla de una forma más tranquila.